

Marco integrativo GQM + PRAGMATIC aplicado a los indicadores PILAR-ENS

Cómo pasar de objetivos nacionales y ENS a métricas técnicas de PILAR sin perder la dignidad metodológica por el camino.

1. Introducción

El propósito de este marco integrativo es alinear tres niveles:

1. Objetivos estratégicos nacionales y del Esquema Nacional de Seguridad (ENS).
2. Preguntas de gestión y gobierno que esos objetivos suscitan.
3. Métricas técnicas concretas proporcionadas (o derivables) de PILAR, evaluadas a su vez con los criterios PRAGMATIC.

La metodología GQM (Goal-Question-Metric) establece el hilo lógico desde los objetivos hasta los datos medibles, mientras que el marco PRAGMATIC sirve para cribar las métricas y quedarnos con las que son útiles, no sólo fáciles de calcular. [web:41][web:44][web:47][web:42][web:45][web:48]

2. Resumen de los elementos de PILAR relevantes para métricas

A efectos de este marco, se consideran los indicadores principales que PILAR ofrece en su integración con ENS:

- Nivel de riesgo por activo, amenaza y dimensión de seguridad, expresado en 0-10 y en color. [web:38][web:40][web:43][web:46]
- Riesgo repercutido (sobre activos esenciales) y acumulado (sobre activos de soporte), navegable por árbol de activos y dimensiones. [web:38]
- Niveles de madurez de salvaguardas y controles L0-L5, con una escala habitual de 0 %, 10 %, 50 %, 80 %, 90 %, 100 %. [web:39][web:18]
- Nivel de recomendación de cada salvaguarda (0-10) por dominio de seguridad, basado en clase de activos, riesgos y capacidad de protección. [web:40][web:43][web:46]
- Semáforo de suficiencia (verde, amarillo, rojo, gris) calculado comparando madurez actual y madurez objetivo de cada medida. [web:1][web:40]
- Estructuras de dominios de seguridad, zonas y fronteras, con herencia de valores de madurez y salvaguardas. [web:39][web:40][web:43]

Estos elementos son la materia prima de las métricas que luego integraremos en GQM y examinaremos con PRAGMATIC.

3. Estructura GQM aplicada al contexto ENS-PILAR

3.1 Objetivos estratégicos de alto nivel (G - Goal)

Se proponen tres objetivos estratégicos genéricos, adaptables a cada organización:

G1. Garantizar que el riesgo residual de los sistemas bajo ENS se mantiene dentro de niveles aceptables y justificados.

G2. Asegurar que las salvaguardas y controles ENS alcanzan un nivel de madurez coherente con los riesgos y los servicios prestados.

G3. Proporcionar a la dirección indicadores claros y fiables para priorizar inversiones y decisiones en seguridad y ENS.

Estos objetivos recogen la esencia de las obligaciones ENS (gestionar riesgos, implantar medidas proporcionales, revisar y mejorar). [web:12]

3.2 Derivación de preguntas (Q – Question) por objetivo

Ejemplos de preguntas clave para cada objetivo:

- G1 – Riesgo residual aceptable
- Q1.1: ¿Qué nivel de riesgo residual soportan actualmente nuestros activos esenciales por dimensión de seguridad?
- Q1.2: ¿Qué activos, dominios o servicios concentran el mayor riesgo repercutido?
- Q1.3: ¿Cuántos riesgos residuales superan umbrales aceptables definidos?
- G2 – Madurez de salvaguardas y controles
- Q2.1: ¿Cuál es el nivel de madurez promedio L0–L5 de las salvaguardas por dominio de seguridad?
- Q2.2: ¿Dónde existe discrepancia significativa entre madurez actual y madurez objetivo?
- Q2.3: ¿Qué medidas están en situación de overkill o underkill?
- G3 – Apoyo a decisiones e inversiones
- Q3.1: ¿Qué salvaguardas tienen mayor recomendación (0–10) y bajo nivel de madurez?
- Q3.2: ¿Qué dominios/sistemas aportan la mayor reducción de riesgo por unidad de inversión?
- Q3.3: ¿En qué medida las métricas disponibles son comprensibles y accionables para la dirección?

Q1.3: ¿Cuántos riesgos residuales superan umbrales aceptables definidos?

G2 – Madurez de salvaguardas y controles

Q2.3: ¿Qué medidas están en situación de overkill o underkill?

G3 – Apoyo a decisiones e inversiones

Las métricas técnicas de PILAR responderán a estas preguntas, pero no todas las métricas posibles serán igual de útiles; ahí entra PRAGMATIC.

4. Selección de métricas (M – Metric) para cada objetivo

A continuación se definen, para cada objetivo, un conjunto de métricas basadas en indicadores PILAR.

4.1 Métricas para G1 – Riesgo residual aceptable

M1.1 – Riesgo medio repercutido de activos esenciales (por dimensión)

- Definición: media del riesgo repercutido (0–10) sobre activos esenciales, separado por confidencialidad, integridad, disponibilidad, etc. [web:38]
- Fuente: árbol de riesgo repercutido de PILAR, nivel activos esenciales. [web:38]

M1.2 – Porcentaje de activos esenciales con riesgo alto ($\geq$ umbral)

- Definición: porcentaje de activos esenciales cuyo riesgo repercutido supera un umbral (por ejemplo, 7/10) en alguna dimensión crítica. [web:38]

M1.3 – Riesgo acumulado por dominio de seguridad

- Definición: suma ponderada del riesgo acumulado de activos de soporte por dominio de seguridad, normalizada a 0–100. [web:38][web:39][web:40]

M1.4 – Número de riesgos residuales por encima del riesgo aceptable

- Definición: conteo de amenazas/escenarios cuyo riesgo residual permanece por encima de la tolerancia definida (por ejemplo, riesgo ≥ 7). [web:38]

4.2 Métricas para G2 – Madurez de salvaguardas y controles

M2.1 – Madurez media L0–L5 de salvaguardas por dominio

- Definición: promedio de madurez de las salvaguardas aplicables en cada dominio, utilizando la escala L0–L5 mapeada a porcentaje. [web:39][web:18]

M2.2 – Porcentaje de salvaguardas en verde (semáforo)

- Definición: porcentaje de medidas cuyo semáforo está en verde (madurez actual $\geq$ objetivo recomendado). [web:1][web:40]

M2.3 – Ratio de medidas en rojo o amarillo respecto al total crítico

- Definición: número de medidas con semáforo rojo/amarillo en salvaguardas con alta recomendación ($\geq 8/10$) dividido por el total de salvaguardas críticas. [web:40][web:46]

M2.4 – Distribución de madurez (L0–L5) en controles ENS obligatorios

- Definición: porcentaje de controles obligatorios en cada nivel de madurez (L0, L1, ..., L5). [web:39]

4.3 Métricas para G3 – Soporte a decisiones e inversiones

M3.1 – Top-N salvaguardas “alto valor, baja madurez”

- Definición: lista de las N salvaguardas con mayor recomendación y menor madurez actual; indicador compuesto más cualitativo, pero tratable numéricamente. [web:40][web:46]

M3.2 – Riesgo reducido por incremento de madurez (sensibilidad)

- Definición: estimación del decremento de riesgo (Δ riesgo) asociado a la subida de una unidad de madurez en determinadas medidas (por dominio o activo). [web:38][web:39]

M3.3 – Índice de cobertura ENS por madurez

- Definición: porcentaje de medidas ENS aplicables que alcanzan al menos un nivel de madurez predeterminado (por ejemplo L3). [web:39]

M3.4 – Relación coste-riesgo mitigado por proyecto

- Definición: cociente entre coste de proyectos de seguridad y riesgo mitigado estimado (puede integrarse con la plantilla ROI).

Estas métricas constituyen el esqueleto a partir del cual se construyen cuadros de mando y justificaciones de inversión.

5. Evaluación PRAGMATIC de las métricas

El acrónimo PRAGMATIC se desglosa en nueve criterios: Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente y Rentable (Cheap/Económico). [web:42][web:45][web:48]

Para cada métrica, se recomienda asignar una puntuación de 1–5 en cada criterio, por ejemplo:

- 1: pobre
- 3: aceptable
- 5: excelente

El resultado es una “metamétrica” que indica qué métricas merecen permanecer en los paneles y cuáles son candidatas a jubilación anticipada.

Ejemplo cualitativo (resumen):

- M2.2 (porcentaje de salvaguardas en verde) suele ser alta en Relevante, Accionable y Significativa, pero puede ser menos Predictiva si no se combina con evolución temporal.
- M3.4 (relación coste-riesgo mitigado) suele destacar en Predictiva y Relevante para decisiones de inversión, pero su Precisión e Independencia dependen mucho de los modelos de estimación del riesgo.

La matriz detallada se presenta en el documento “Matriz de Evaluación PRAGMATIC Completa”.

6. Integración práctica en la organización

En la práctica, el marco se aplica así:

4. Seleccionar objetivos ENS–PILAR relevantes (G).
5. Formular preguntas de negocio y gobierno (Q) que la dirección quiera ver respondidas.
6. Elegir, entre las métricas posibles de PILAR (M), aquellas que mejor respondan a las preguntas.
7. Evaluar las métricas con PRAGMATIC y descartar las que, aun siendo fáciles de obtener, aportan poco valor.
8. Consolidar las métricas supervivientes en cuadros de mando, vinculadas al IGM y al ROI de seguridad.

Este bucle, aplicado iterativamente, permite depurar el conjunto de indicadores, evitando el síndrome del “panel de control que parece una cabina de avión pero nadie usa”.

7. Notas de adaptación

- El marco GQM + PRAGMATIC es independiente de la versión concreta de PILAR, siempre que se mantengan los conceptos de riesgo, madurez, recomendación y semáforos. [web:1][web:38][web:39][web:40][web:43][web:46]
- Puede extenderse con métricas adicionales (tiempos de respuesta a incidentes, SLA de continuidad, etc.) siempre que se actualicen las evaluaciones PRAGMATIC.
- Es recomendable revisar anualmente la batería de métricas para evitar “crecimiento vegetativo” de indicadores obsoletos.